

Vulnerability & Patch- Management

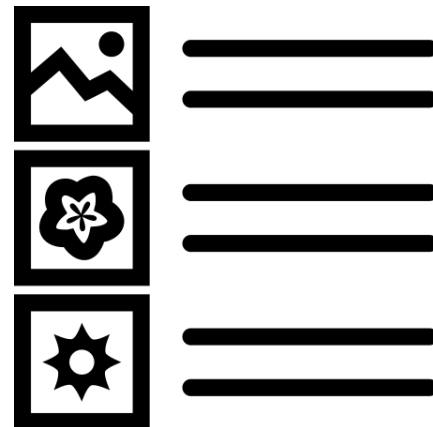
Identifying, evaluating, treating, and reporting on security vulnerabilities
Fix and remove security vulnerabilities



SOC.F2601
Peter Infanger, HSLU I

Programm

- Einführung
- Weshalb?
- Was ist Vulnerability Management?
- Grundsätzliches & Hintergrund
- Standards & Frameworks
- Vulnerability Assessment
- Produkte
- Vulnerability Quellen
- CVE, CVSS
- Patch Management



Einführung

Vulnerability = Schwachstelle

Und dann gibt es die: 5 Laws of Cybersecurity*

1. If There Is A Vulnerability, It Will Be Exploited
2. Everything Is Vulnerable In Some Way
3. Humans Trust Even When They Shouldn't
4. With Innovation Comes Opportunity For Exploitation
5. When In Doubt, See Law No. 1

Weshalb?

- Laut einer aktuellen Forrester Global Security Survey haben 49 Prozent der Unternehmen im vergangenen Jahr einen oder mehrere Sicherheitsverstösse erlitten, und Software-Schwachstellen waren der grösste Faktor bei diesen Verstössen.
- Hinzu kommt, dass Prognosen für das Jahr 2025 mit über 45'000 neue Sicherheitslücken vorausgesagt wurden* und für einen bedeutenden Anteil dieser Vulnerabilites ein Exploit verfügbar war.
- Das zeigt wie wichtig es ist, dass Unternehmen das Vulnerability Managements in ihre Sicherheitsstrategien mit einbeziehen.

→ Denn es braucht nur eine einzige Schwachstelle, damit sich die Bösewichte heimlich einschleichen und Daten stehlen können.

Weshalb? (2)

- Nicht umsonst wird in den Top 10 der Sicherheitskontrollen, die das **Center for Internet Security** (CIS*) veröffentlicht hat, so viel Wert auf Vulnerability Management gelegt.

The 18 CIS Critical Security Controls

Formerly the SANS Critical Security Controls (SANS Top 20) these are now officially called the CIS Critical Security Controls (CIS Controls).

CIS Controls Version 8 combines and consolidates the CIS Controls by activities, rather than by who manages the devices. Physical devices, fixed boundaries, and discrete islands of security implementation are less important; this is reflected in v8 through revised terminology and grouping of Safeguards, resulting in a decrease of the number of Controls from 20 to 18. Click on the individual CIS Control for more information:

CIS Control 1: [Inventory and Control of Enterprise Assets](#)

CIS Control 2: [Inventory and Control of Software Assets](#)

CIS Control 3: [Data Protection](#)

CIS Control 4: [Secure Configuration of Enterprise Assets and Software](#)

CIS Control 5: [Account Management](#)

CIS Control 6: [Access Control Management](#)

CIS Control 7: [Continuous Vulnerability Management](#)

CIS Control 8: [Audit Log Management](#)

CIS Control 9: [Email and Web Browser Protections](#)

CIS Control 10: [Malware Defenses](#)

*Source: <https://www.cisecurity.org/controls/cis-controls-list>





Weshalb? (3)

- Ausserdem ist das Patchen der durch Vulnerability Management aufgedeckten Schwachstellen **eine der kosteneffektivsten Massnahmen zur Minimierung des Cyberrisikos** → haben Vulnerability Scanner eine Schwachstelle aufgedeckt gibt es vielfach bereits einen Patch dafür beim Hersteller des Produkts.

Es macht keinen Sinn, viel Geld in Systeme wie IDS, IDP, EDR usw. zu stecken solange kein vernünftiges Vulnerability & Patch-Management implementiert ist!

- Der Prozess des Vulnerability Scanning lässt sich sehr gut automatisieren, so das sich der personelle Aufwand hierfür recht gut minimieren lässt. (Die Auswertung der Resultate hingegen sollte sorgfältig durchgeführt werden)
- **Achtung:** der Vulnerability Scanner findet in der Regel keine zero-day Lücken weil er nicht danach suchen kann!

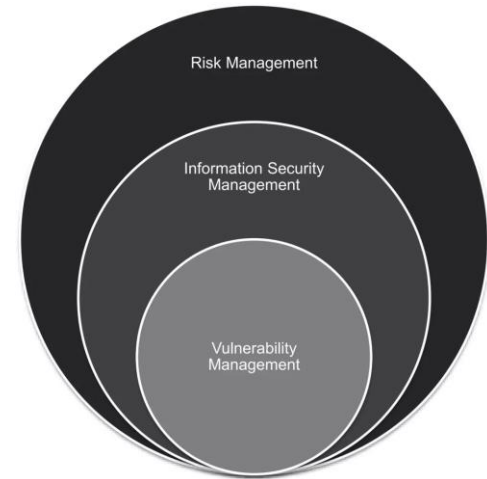
Arten von Vulnerabilities

- Welche Arten von Vulnerabilities gibt es denn?
 - Software Bugs
 - Buffer overflow
 - Privilege Escalation
 - ...
 - Fehlkonfigurationen, fehlende oder nicht effektive Sicherheitsmassnahmen
 - TLS nicht richtig konfiguriert (SSL 1.0 zugelassen)
 - Antivirus nicht installiert bzw. nicht aktuell
 - ...
 - Prozessschwächen (Organisatorische Probleme)
 - Mitarbeiter lässt Angreifer in Gebäude
 - Herausgabe von Guest-Badges nicht gut kontrolliert
 - ...
 - Menschliches Fehlverhalten - Anfälligkeit auf Social Engineering
 - Mitarbeiter fällt auf Phishing-Mail rein
 - Mitarbeiter verifiziert Zahlungsinstruktion nicht genügend
 - ...

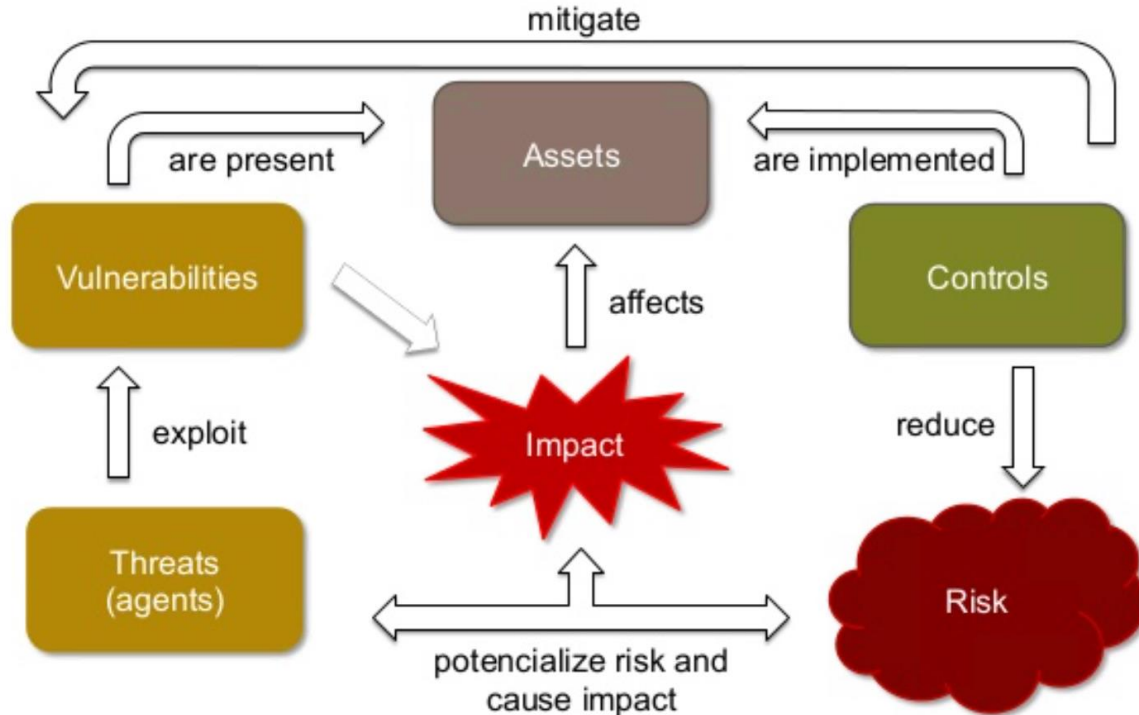


Vulnerability Management

- Vulnerability Managements ist ein **zyklischer Prozess**, bei dem IT-Ressourcen identifiziert und mit einer ständig aktualisierten Schwachstellendatenbank korreliert werden, um Bedrohungen, Fehlkonfigurationen und Schwachstellen zu identifizieren.
- Ein weiterer wichtiger Aspekt des Vulnerability Managements ist die **Bewertung der Dringlichkeit** und Auswirkung jeder Schwachstelle auf der Grundlage verschiedener Risikofaktoren und die schnelle Reaktion auf kritische Bedrohungen.
- Geht Hand-in-Hand bzw. ist Bestandteil des Risikomanagement



Wieso spielt das überhaupt eine Rolle?



Grundsätzliches

- Ist ein Prozess (Teil des Risikomanagements) der im Prinzip folgende Teile umfasst:
 - Erkennen und Identifikation der Vulnerability
 - Einstufung der Vulnerability
 - Bewertung der Dringlichkeit (Entscheidungsfindung)
 - Mitigierung (Gegenmassnahmen ergreifen, z.B. **Software patchen**)
- Es gibt verschiedene Framework/Standards, welche diese Teile direkt umsetzen oder um weitere Elemente wie Baseline, Verify, etc. ergänzen (ISO 27K, SANS, NIST, ...)



Hintergrund

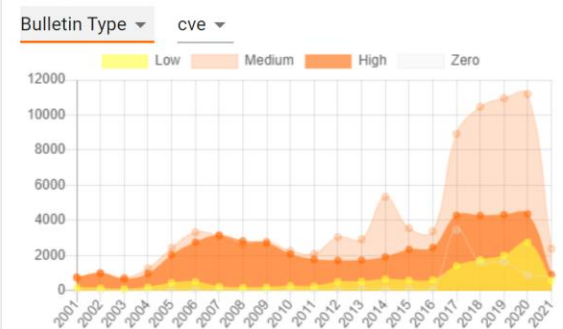
- Herkunft der Vulnerabilities:
 - Programmierfehler (Schönwetterprogramme :-)
 - Konfigurationsfehler
 - Fehler beim Erzeugen der Programme (Build- bzw. Compilerfehler)
 - Menschliches Fehlverhalten (Social Engineering)
 - ...

- Schätzungen gehen von einem Fehler pro ca. 1500 Zeilen Sourcecode aus!

(Quelle: <https://www.computerwoche.de/article/2732708/open-source-gleichauf-mit-proprietärer-software.html>)

Vulnerabilities progression

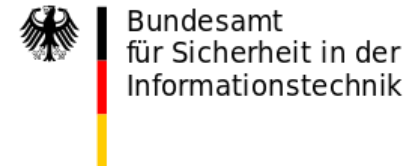
Visualization of security bulletins appearance in recent years divided by types and families



Quelle: <https://vulners.com/stats>

Standards und Frameworks

- ISO
- NIST
- PCI DSS
- BSI
- CIS
- OWASP
- OSSTMM
- ...



Vulnerability Management (nach SANS)

Das **Vulnerability Management Maturity Model** beschreibt die Entwicklungsstufen eines Schwachstellenmanagement-Programms

- Von reaktivem Patchen bis hin zu strategischer, automatisierter Risikominimierung.
- Es hilft Unternehmen, ihre Prozesse zu bewerten und gezielt zu verbessern

Man kann das Modell nutzen, um sein eigenes Schwachstellenmanagement zu bewerten oder eine Roadmap zur Verbesserung zu entwickeln.

Vulnerability Management Maturity Model

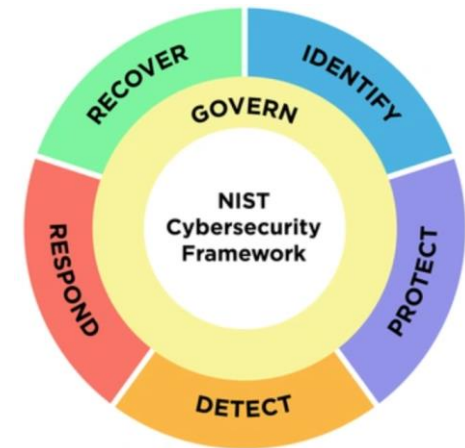
	LEVEL 1 Initial	LEVEL 2 Managed	LEVEL 3 Defined	LEVEL 4 Quantitatively Managed	LEVEL 5 Optimizing
Prepare	Policy & Standards Policy and standards are undocumented or in a state of change.	Policy and standards are defined in specific areas as a result of a negative impact to the program rather than based on a deliberate selection of best practices or standards from recognized frameworks.	Policy and standards have been carefully selected based on best practices and recognized security frameworks and are updated as needed to fulfill the program's mission. Employees are made aware of standards and training on requirements is available.	Adherence to defined policy and standards is tracked and deviations are highlighted. Training of personnel on requirements is required at least annually.	Automated, proactive controls enforce policy and standards and provide input to regular updates and training requirements.
	Context Contextual data (e.g., asset details, ownership, relationships) are available from multiple data sources with varying degrees of accuracy.	There is a central repository of contextual data that has some data for most systems and applications.	The central repository requires that certain contextual information be tracked and updated for every system and that it is based on program needs.	Reports show compliance with contextual information requirements and processes are in place to identify non-compliance, missing, or retired systems and applications.	Automated or technology-assisted processes and procedures exist to both create and remove systems and applications and associated attributes from the central repository, or data are correlated and reconciled with other systems that contain information about tracked systems and applications.
Identify	Automated Infrastructure and applications are scanned ad-hoc or irregularly for vulnerability details, or vulnerability details are acquired from existing data repositories or from the systems themselves as time permits.	The process, configuration, and schedule for scanning infrastructure and applications is defined and followed for certain departments or divisions within the organization. Available technology may vary throughout the organization.	There are defined and mandated organization-wide scanning requirements and configurations for infrastructure and applications that set a minimum threshold for all departments or divisions. Technology is made available throughout the organization through enterprise licensing agreements or as a service.	Scanning coverage is measured and includes the measurement of authenticated vs. unauthorized scanning (where applicable), the types of automated testing employed, false positive rates, and vulnerability escape rates.	Scanning is integrated into build-and-release processes and procedures and happens automatically in accordance with requirements. Scanning configurations and rules are updated based on previous measurements.
	Manual Manual testing or review occurs when specifically required or requested.	Manual testing or review processes are established and some departments and divisions have defined requirements.	Manual testing or review occurs based on reasonable policy-defined requirements that apply to the entire organization and is available as a service where not specifically required by policy.	Deviations from manual testing or review requirements are tracked and reported.	Manual testing or review processes include focused testing based on historical test data and commonalities or threat intelligence.
	External External vulnerability reports and disclosures are handled on a case-by-case basis.	Basic vulnerability disclosure policy (VDP) and incident mitigation procedures, but lacking processes and procedures not documented.	More comprehensive VDP in place, along with terms and conditions for external vendors and security researchers, that outlines rules of engagement, tracking, and feedback processes.	Compliance with VDP and terms and conditions is tracked and measured and information is used to streamline processes and evaluate vendors and researchers.	A mature external testing and research program is in place with specific goals and campaigns that may only be available to specific vendors or researchers.
Analyze	Prioritization Prioritization is performed based on out-of-the-box information generated by identification technology or indicated in reports.	Prioritization also includes analysis of other available fields such as whether or not exploits or malware exist or confidence scores.	Prioritization includes correlation with the threat intelligence for external vendors and security researchers, that outlines rules of engagement, tracking, and feedback processes.	Generic threat intelligence or other custom data, which may require additional products or services, are leveraged to perform prioritization.	Company-specific threat intelligence, or other information gathered from the operating environment, is leveraged to perform prioritization. This information may require human analysis or more extensive customization.
	Root Cause Analysis Root cause analysis is performed based on out-of-the-box information such as standard remediation/patch reports or other categorized reports (e.g., ONSAP Top 10 category).	Data are lightly customized to apply less filtered by department or location of data than CVE, CWE, or Top 10 identifiers to facilitate root cause analysis.	Data are also identified, grouped, and/or filtered by department or location to enable identification of location- or group-based deficiencies. This may require light to moderate customization depending on architecture and design.	Data are also identified, grouped, and/or filtered by owner or role. This may require more extensive customization and ongoing maintenance.	An executive dashboard is in place and includes the highest-risk root cause findings, exclusions, project cost projections, etc. This will require more detailed analysis and customization to become meaningful and should integrate with existing executive business intelligence tools.
Communicate	Metrics & Reporting Simple, point-in-time operational metrics are available primarily sourced from out-of-the-box reports leveraging minimal customization or filtering.	Filtered reports are created to target specific groups or priorities findings. Specific divisions or departments have defined their own reporting requirements, including both program and operational metrics, and generate and release the corresponding reports at a defined interval.	Reporting requirements, including all required program, operational, and executive metrics and trends, are well-defined and baseline reports are consistent throughout the organization and tailored or filtered to the individual departments or stakeholders.	Reports and metrics include an indication of compliance with defined policy and standards, treatment timelines, and bug bars. Correlation with other security or contextual data sources allows for more meaningful grouping, improves accuracy, and allows for identification of faulty or inefficient design patterns.	Custom reporting is available as a service or via self-service options, or feedback is regularly solicited and reports are updated to reflect changing needs. Automated outlier and trend analysis along with exclusion tracking is performed to identify high-low performers and highlight systemic issues/successes.
	Alerting Alerting is either not available or only available within security-specific technologies.	Integrations exist and alerts are being sent for specific divisions or departments or for users of specific non-security technologies already being leveraged by some stakeholders.	Alerting is available for most stakeholders in their technology of choice.	Visibility and both timing and detail of response to alerts is measured and tracked.	Data are analyzed to develop a standard or automated response to alerts for common issues that can be tied to a common response.
Treat	Change Management Changes related to vulnerability management activities pass through the same workflow as any other change.	Some changes related to vulnerability management activities have a custom workflow or are treated as standard changes.	Most changes related to vulnerability management activities follow a custom workflow or are treated as standard changes.	Changes related to vulnerability management activities along with success rates are tracked. Timing is also measured for different stages of the change or subtasks related to the change.	Metrics from vulnerability management change activities are used to modify requirements or streamline future change requests. At least some standard changes are automated.
	Patch Management Patches are applied manually or scheduled by admins and end-users.	There is a standard schedule defined and technology is available for some divisions or departments or for some platforms to automate patch testing and deployment.	All departments are required to patch within a certain timeframe and technologies are available to assist with testing and applying patches for all approved platforms.	Patch management activities are tracked along with compliance with remediation timelines and the success rate.	Data from patch management activities, security incidents, and threat intelligence are used to right-size remediation timelines and identify process or technology changes.
	Configuration Management Configuration requirements are not well-defined and changes are either applied manually or the automatic application of configurations is only available for a subset of platforms.	Configurations are defined for some divisions or departments or for specific platforms.	Configurations are defined for all supported platforms and technologies are available to automate or validate configuration changes for all platforms.	Deviations from configuration requirements and associated service impacts are measured and tracked.	Data from the configuration process along with security incidents and threat intelligence are leveraged to strengthen or relax requirements as needed.

Vulnerability Management nach NIST

Cybersecurity Framework (<https://www.nist.gov/cyberframework>)

Massnahmen Empfehlungen des NIST Cybersecurity Framework:

1. Asset-Vulnerability werden identifiziert und dokumentiert.
2. Informationen über Bedrohungen und Vulnerabilities werden von Foren und Quellen zum Informationsaustausch erhalten.
3. Interne und externe Bedrohungen werden identifiziert und dokumentiert.
4. Bedrohungen, Vulnerabilities, Wahrscheinlichkeiten und Auswirkungen werden zur Risikoermittlung herangezogen.
5. Massnahmen zur Risikobewältigung werden identifiziert und priorisiert.
6. Der Vulnerability Managementplan wird entwickelt und umgesetzt.
7. Ereignisdaten werden von mehreren Quellen und Sensoren aggregiert und korreliert.
8. Vulnerability Prüfungen werden durchgeführt.
9. Neu identifizierte Vulnerability werden gemildert oder als akzeptierte Risiken dokumentiert.



Vulnerability Assessment

Umfassen verschiedene Aktivitäten:

- Festlegen eine Policy:
 - was soll geprüft werden?
 - wann soll geprüft werden?
 - wie soll geprüft werden?
 - festlegen des Vorgehens bei Findings
 - Re-Test oder nicht?
- Miteinbezug des Patching-Prozesses
- Reporting

Asset discovery



Detect and manage local and remote endpoints, roaming devices, and closed network (DMZ) machines.

Vulnerability Assessment (2)

- Welche Möglichkeiten es für das Assessment gibt:
 - Netzwerkbasierte Scans
 - WLAN-Scans
 - Host-basierte Scans (z.B. zur Überprüfung der Systemkonfiguration)
 - "full-blown" Penetration Test (Anwendungsscans)

Mit Agenten auf Host:

- Authentisiert
- Privilegierter Benutzer

Agent-less:

- ev. beschränkte Sicht
- beschränkte Mittel (fehlende Privilegien)

Vulnerability Assessment (3)

Authentisiert / Un-authentisiert

- Authentifiziert:

- weniger Vulnerability Falschmeldungen
- weniger störend für die Geräte

- nicht Authentifiziert:

- "Sehen, was Angreifer sehen"
- Das Sicherheitsteam benötigt keine Anmeldeinformationen
- Sollte nicht als "Black Box"-Test durchgeführt werden

Vulnerability Assessment != Penetrationstests

Vulnerability Assessment vs. Pentesting (1)

Vulnerability Assessment

Pre-engagement Interactions

Intelligence Gathering

Threat Modeling

Vulnerability Analysis

Reporting

Penetration Test

Pre-engagement Interactions

Intelligence Gathering

Threat Modeling

Vulnerability Analysis

Exploitation

Post Exploitation

Reporting

Vulnerability Assessment vs. Pentesting (2)

Vulnerability Assessment

Usually has a broader scope than Penetration Test

Predictable, because network adm is aware of the tools being used

May include several false positives

Produces a report with recommendations for risk reduction

Penetration Test

Exploits specific attack vectors (services or assets)

May happen unannounced, to test incident response

Trustworthy because provides evidence of break in (root!)

Pen Testing = Proof of Concept against vulnerabilities

Produces a binary result: got root or not

Vulnerability Scanning

- Mehrere Techniken sollten kombiniert werden.
 - Passiv/kontinuierlich: Überwacht den Netzwerkverkehr.
 - Aktiv: Sendet Daten an Geräte, um eine Antwort zu erzeugen.
 - Authentisiert: Anmeldungen an einzelnen Systemen
 - Agent: Dedizierter Agent, der auf einer Teilmenge von Geräten installiert ist
- Vorteile:
 - Sichtbarkeit, Asset Value , Gruppierung

Vulnerability scanning



Spot all OS and third-party vulnerabilities, including vulnerabilities in content management systems, web servers and database software.

Vulnerability Scanning

Übersicht:

Merkmal	Mit Agenten	Ohne Agenten	Passives Netzwerk- monitoring
Benötigt Admin Privilegien auf dem Host	ja	ja	nein
Unterstützung für nicht verwaltete Hosts (z.B. Appliances)	nein	nein	ja
Unterstützung für entfernte Hosts	Ja	nein	nein
Benötigte Bandbreite für Scan	minimal	mittel bis umfangreich	keine
Applikations-Erkennungs-Potential	umfassend	~umfassend	schwierig bei verschlüsseltem Traffic

Probleme beim Assessment

false-positives: sind unerwünscht da sie Aufwand bedeuten und eigentlich keine Erkenntnisse liefern.

Ursachen:

- Auslesen einer falschen (Software-)Version
- falsches interpretieren von Resultaten

false-negatives: eine Vulnerability existiert und wird beim Assessment nicht erkannt → **worst case!**

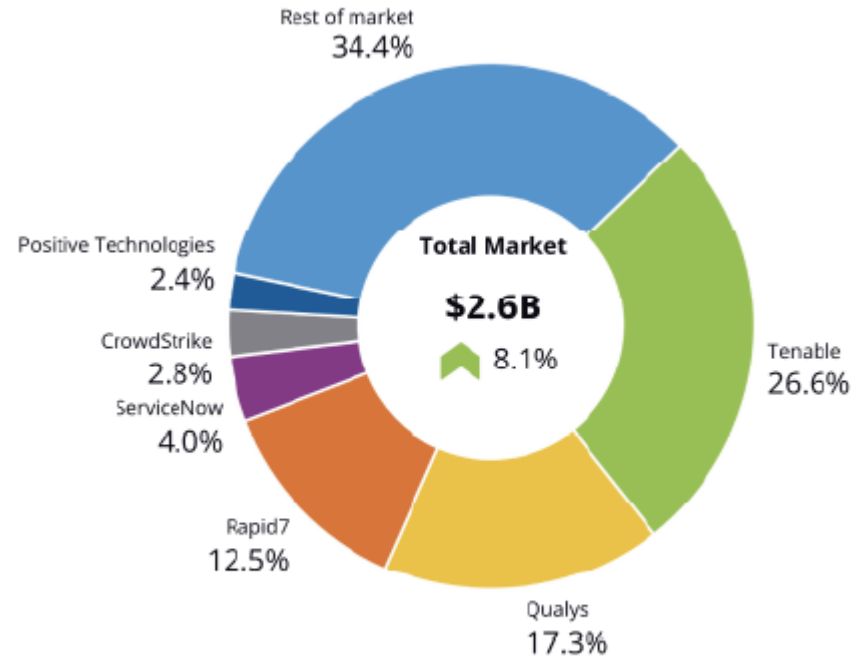
Ursachen:

- Komponente/Prozess/Service läuft zum Scanning-Zeitpunkt nicht
- keine/zu geringe Berechtigung um Komponente/Prozess/Service zu testen
- Wird durch alternative (nicht erkannte) Massnahmen (NGFW, Proxy, WAF, ...) geschützt

Beispiel - Produkte

Key Players:

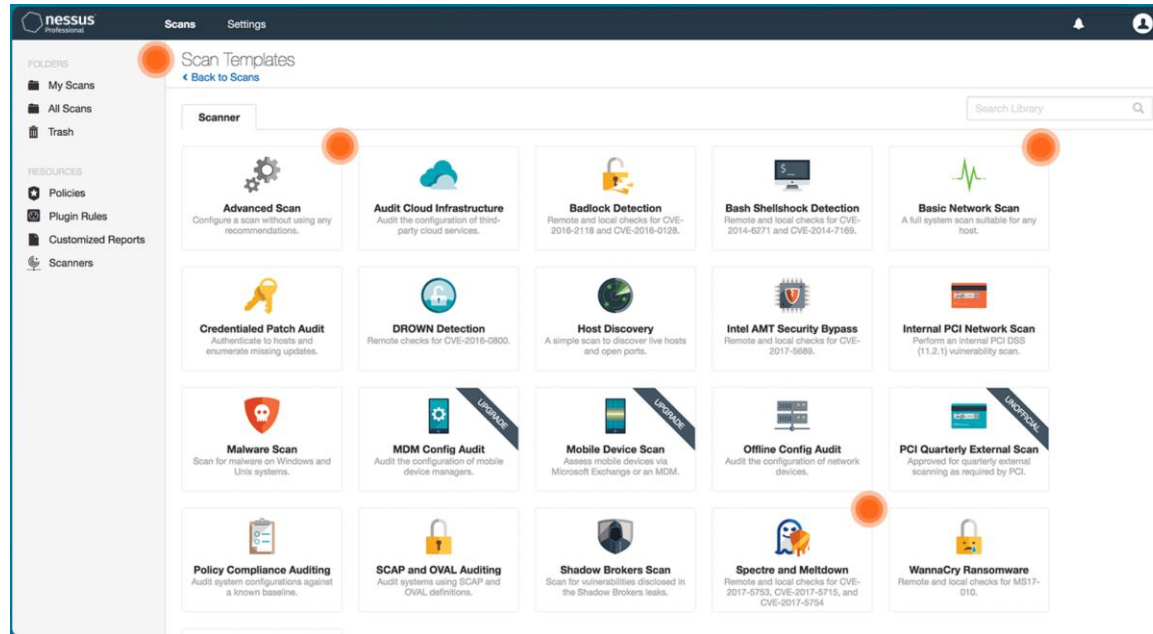
- Tenable – nessus
- Qualys
- Rapid7



Source: IDC: "Worldwide Device Vulnerability and Exposure Management Market Shares, 2024," IDC #US53330526, August 2025

Tenable - nessus

- Ein weit verbreiteter, professioneller Vulnerability Scanner



Qualys VMDR

A new approach is required.

Qualys VMDR with Built-in Orchestration

Discover, assess, prioritize, and patch critical vulnerabilities in real time and across your global hybrid-IT landscape — all from a single solution.



Identify all known and unknown assets on your global hybrid-IT

Knowing what's active in a global hybrid-IT environment is fundamental to security. Automatically detect all known and unknown IT assets everywhere for a complete, categorized inventory enriched with details such as vendor lifecycle information and much more.



Quickly focus on what's most urgent

Using advanced correlation and machine learning, automatically prioritize the riskiest vulnerabilities on the most critical assets, reducing thousands of vulnerabilities to the few hundred that matter.



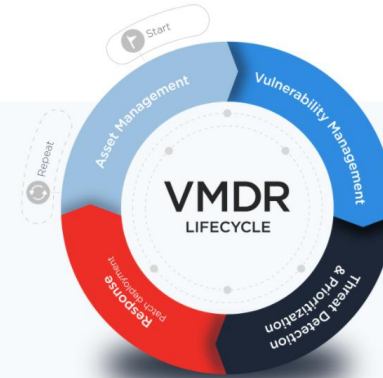
Analyze vulnerabilities and misconfigurations with six sigma accuracy

Automatically detect vulnerabilities and critical misconfigurations per CIS benchmarks, by asset.



Inoculate your assets from the most critical threats

With the push of a button, deploy the most relevant, superseding patch to quickly remediate vulnerabilities and threats across any size environment.



OpenVAS

- Open-Source Lösung zum Vulnerability Assessment



Greenbone OpenVAS

OpenVAS is a full-featured vulnerability scanner. Its capabilities include unauthenticated and authenticated testing, various high-level and low-level internet and industrial protocols, performance tuning for large-scale scans and a powerful internal programming language to implement any type of vulnerability test.

The scanner obtains the tests for detecting vulnerabilities from a [feed](#) that has a long history and daily updates.

OpenVAS has been developed and driven forward by the company [Greenbone](#) since 2006. As part of the commercial vulnerability management product family Greenbone Enterprise Appliance, the scanner forms the [Greenbone Community Edition](#) together with other open-source modules.

Read more about the history of OpenVAS [here](#).

Related Links



Products



Test Now



Product
Documentation



Security Response
Team



Source Code



Community Forum

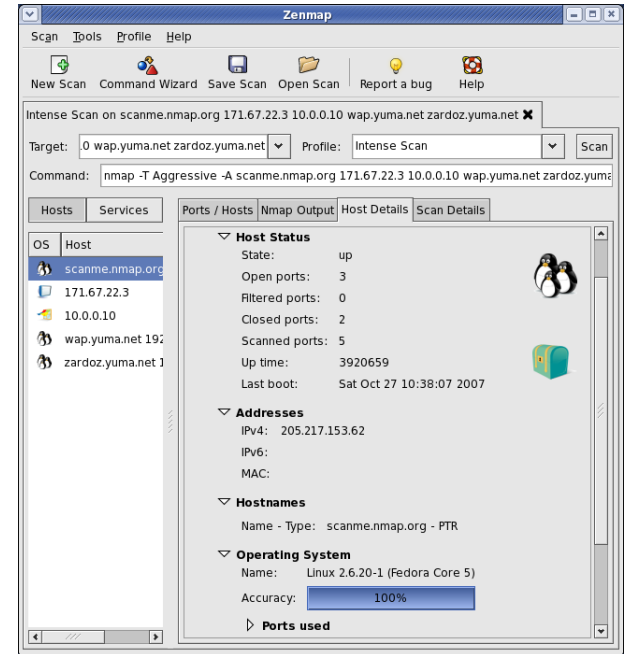
Und für den Hausgebrauch: nmap



- Eigentlich "nur" ein Netzwerk-Scanner welcher um Features für Security Scanning erweitert wurde
- Sowohl CLI als auch GUI verfügbar (zenmap)

```
kali@kali:~$ sudo nmap -sV 209.165.200.235
[sudo] password for kali:
Starting Nmap 7.80 ( https://nmap.org ) at 2021-03-19 07:39 EDT
Nmap scan report for 209.165.200.235
Host is up (0.00064s latency).
Not shown: 977 closed ports
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet?
25/tcp    open  smtp?
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec?
513/tcp   open  login?
514/tcp   open  shell?
1099/tcp  open  java-rmi     GNU Classpath gmrregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  cproxy-ftp?
3306/tcp  open  mysql        MySQL (Too many connections)
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  x11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  unknown
Service Info: Host: irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 193.19 seconds
kali@kali:~$
```



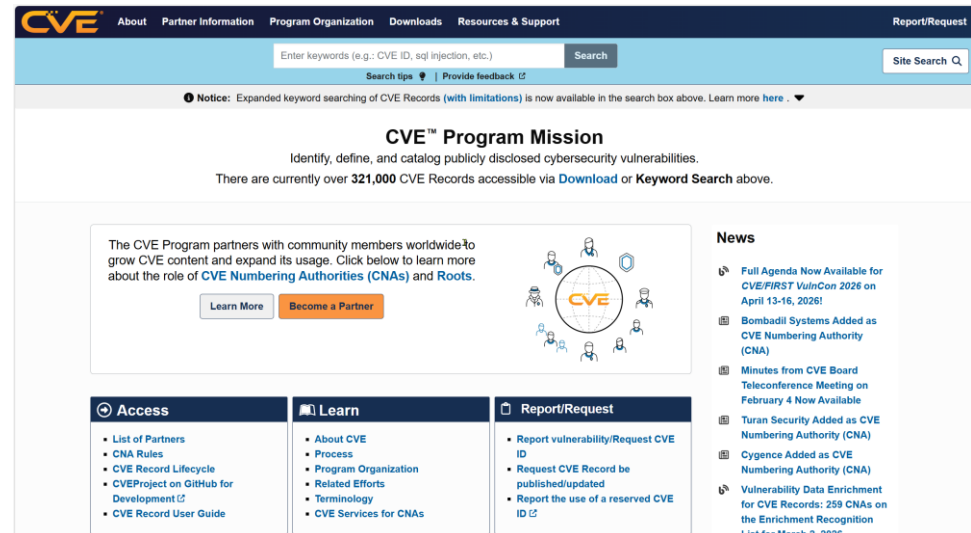
Woher kommen die Informationen zu Vulnerabilities?

- Es gibt viele verschiedene Quellen welche Hinweise auf Vulnerable Produkte liefern:
 - Hersteller bzw. Lieferant der betroffenen Devices, z.B. Broadcom:
<https://www.broadcom.com/support/security-center/protection-bulletin>
oder Cisco: <https://sec.cloudapps.cisco.com/security/center/publicationListing.x>
 - eigene DB der eingesetzten Vulnerability-Tools
 - öffentliche DB's und andere OSINT Quellen
 - Vulners: <https://vulners.com>
 - MITRE <https://cve.mitre.org/data/refs/refmap/source-BUGTRAQ.html>
 - CERT's <http://www.kb.cert.org/vuls>
 - NIST <https://nvd.nist.gov>
 - bugtraq <https://www.securityfocus.com> → leider offline (Archiv:
<https://seclists.org/bugtraq/>)

Andere Quellen über Vulnerabilities

Common Vulnerabilities and Exposures (CVE) (<https://www.cve.org/>):

- Die CVE-Kennung bietet eine standardisierte Möglichkeit, einen Verweis auf Schwachstellen zu recherchieren.
- Bedrohungsnachrichtendienste verwenden CVE-Kennungen, und sie erscheinen in verschiedenen Sicherheitssystemprotokollen.
- Über die Suchfunktionen lassen sich schnell CVEs suchen und eine Verknüpfung zwischen CVE-Informationen und dem CVSS-Score herstellen.



The screenshot shows the CVE Program Mission page. At the top is a navigation bar with links: About, Partner Information, Program Organization, Downloads, Resources & Support, and a Report/Request link. Below the navigation bar is a search bar with the placeholder text "Enter keywords (e.g.: CVE ID, sql injection, etc.)" and a Search button. To the right of the search bar is a Site Search link. Below the search bar is a notice: "Notice: Expanded keyword searching of CVE Records (with limitations) is now available in the search box above. Learn more here." The main heading is "CVE™ Program Mission" with the subtext "Identify, define, and catalog publicly disclosed cybersecurity vulnerabilities." Below this, it states "There are currently over 321,000 CVE Records accessible via Download or Keyword Search above." The main content area features a paragraph: "The CVE Program partners with community members worldwide to grow CVE content and expand its usage. Click below to learn more about the role of CVE Numbering Authorities (CNAs) and Roots." Below this paragraph are two buttons: "Learn More" and "Become a Partner". To the right of the paragraph is a circular diagram with the CVE logo in the center and icons representing various stakeholders around it. On the right side of the page is a News section with several items: "Full Agenda Now Available for CVE/FIRST VulnCon 2026 on April 13-16, 2026!", "Bombadil Systems Added as CVE Numbering Authority (CNA)", "Minutes from CVE Board Teleconference Meeting on February 4 Now Available", "Turan Security Added as CVE Numbering Authority (CNA)", "Cygence Added as CVE Numbering Authority (CNA)", and "Vulnerability Data Enrichment for CVE Records: 259 CNAs on the Enrichment Recognition List for March 2, 2026". At the bottom of the page are three columns: "Access" with links to List of Partners, CNA Rules, CVE Record Lifecycle, CVEProject on GitHub for Development, and CVE Record User Guide; "Learn" with links to About CVE, Process, Program Organization, Related Efforts, Terminology, and CVE Services for CNAs; and "Report/Request" with links to Report vulnerability/Request CVE ID, Request CVE Record be published/updated, and Report the use of a reserved CVE ID.

MITRE <https://www.cve.org/>

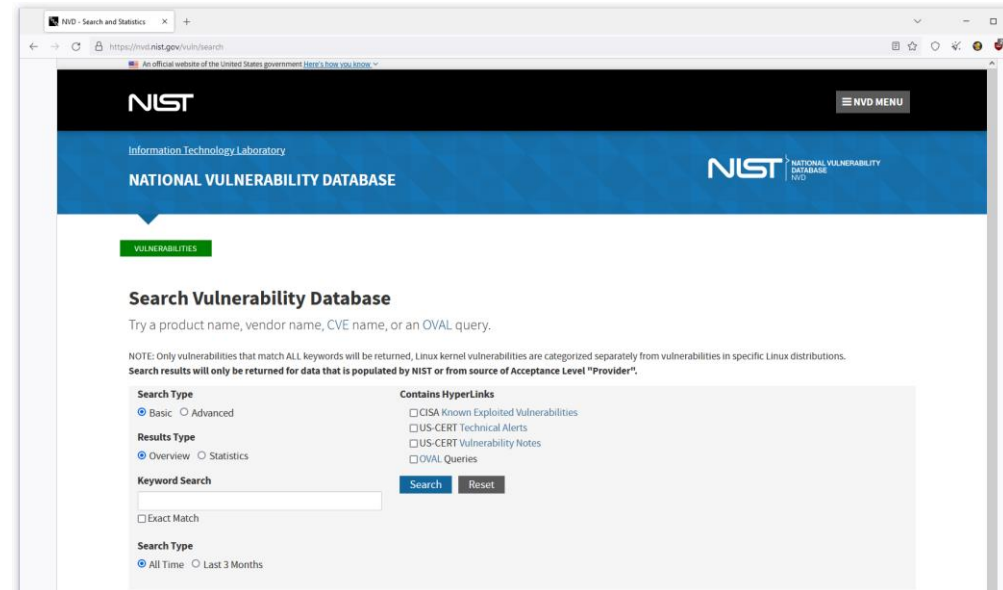
Andere Quellen über Vulnerabilities (2)

Nationale Datenbank für Sicherheitsrisiken (NVD):

- Diese verwendet CVE-Kennungen und liefert zusätzliche Informationen zu Schwachstellen wie CVSS-Bedrohungsbewertungen, technische Details, betroffene Unternehmen und Ressourcen für weitere Untersuchungen.

Die Datenbank wurde von der US-Regierungsbehörde National Institute of Standards and Technology (NIST) erstellt und wird von ihr gepflegt.

NIST <https://nvd.nist.gov/vuln/search>



Vulnerabilities & Threat Intelligence



Aufgabe:

1. Finden Sie den/die CVE(s) für "WannaCry"
2. Welche Voraussetzungen waren gemäss CVE(s) notwendig um diese Attacke erfolgreich durchzuführen?
3. Definieren Sie einige Massnahmen, welche diese Attacke effektiv abwenden.

Security Content Automation Protocol (SCAP)

Das Security Content Automation Protocol (SCAP) umfasst mehrere Spezifikationen zur **Benennung** und **Kommunikation** von Vulnerabilities und allgemein sicherheitsrelevanten Informationen.

Diese Spezifikationen gliedern sich in verschiedene Sprachen, Formate, Auflistungen, Bewertungssysteme sowie eines Modells zum Erhalt der Integrität.

Die für die Kommunikation von Vulnerability relevantesten Spezifikationen umfassen das (Auszug):

- Common Configuration Enumeration (CCE),
- Common Platform Enumeration (CPE),
- Common Vulnerabilities and Exposures (CVE),
- Common Configuration Scoring System (CCSS)
- ...

SCAP consists of a suite of specifications for standardizing the format and nomenclature by which security software communicates information about software flaws and security configurations. (Zitat NIST)

Quelle: <https://www.nist.gov/news-events/news/2018/04/nist-releases-nist-internal-report-nistir-7511-revision-5-security-content>

Common Vulnerability Scoring System (CVSS)

- Das Common Vulnerability Scoring System (CVSS) ist ein Werkzeug zur Risikobewertung welches die Gemeinsamkeiten und den Schweregrad von Schwachstellen in Computerhardware- und Softwaresystemen **vermitteln** soll.
- CVSS liefert **standardisierte Schwachstellenbewertungen**.
- Es stellt ein offenes Rahmenwerk mit Metriken für alle Benutzer zur Verfügung.
- CVSS hilft bei der Priorisierung von Risiken.
- Das *Forum of Incident Response and Security Teams* (FIRST) wurde zum Verwalter von CVSS ernannt, um dessen weltweite Einführung zu fördern.

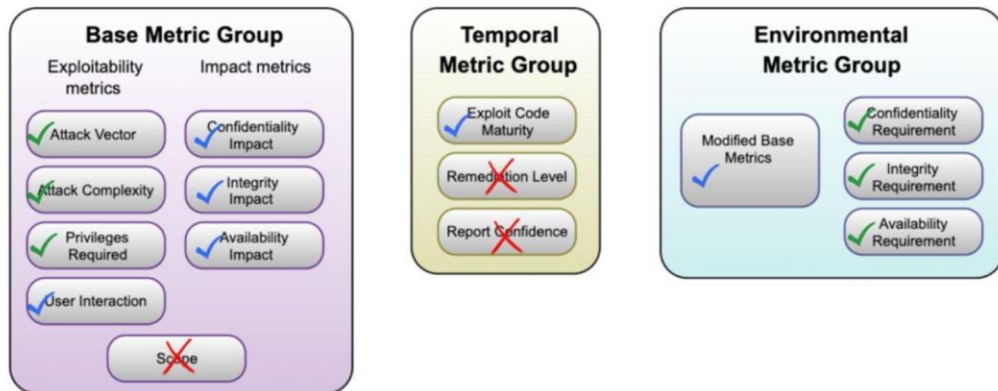
<https://www.first.org/cvss/>



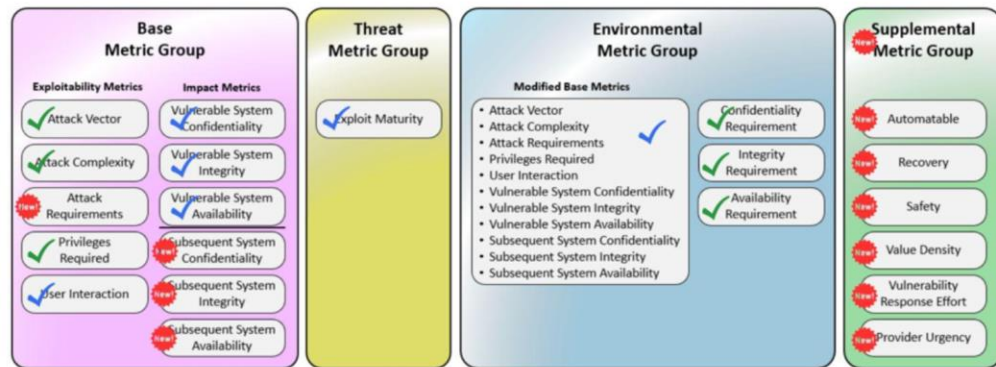
Updates des CVSS-Systems

- Aufgrund vielschichtiger Kritik wurde das CVSS v4.0 im Jahr 2023 veröffentlicht.
- CVSS 4.0 wurde entwickelt, weil die alte Version 3.1 viele reale Risiken nicht präzise genug abbildete.
- Sie erhöht die Präzision, trennt technische Schwere klar von der Bedrohungslage und ergänzt passende Metriken für moderne Angriffe.
- Viele Vulnerabilities werden heute aber immer noch in der Version 3.1 veröffentlicht.

Common Vulnerability Scoring System v3.1



Common Vulnerability Scoring System v4



Existing Component



Existing Component w/ Substantial Changes



No Longer a CVSS Component in V4



New CVSS V4 Component

CVSS Metrik Gruppen

Base Metrics

- Beschreiben die grundlegende technische Schwere einer Schwachstelle.
- Unabhängig von Zeit, Umgebung oder aktueller Bedrohung.

Threat Metrics (neu in CVSS 4.0)

- Zeigen, wie stark eine Schwachstelle aktuell ausgenutzt wird.
- Spiegeln die reale Bedrohungslage wider (z. B. Exploits in Umlauf).

Environmental Metrics

- Passen die Bewertung an die spezifische Umgebung einer Organisation an.
- Berücksichtigen z. B. Schutzmassnahmen, betroffene Systeme oder Auswirkungen vor Ort.

Supplemental Metrics

- Ergänzende Informationen, die nicht in den Score einfließen, aber Kontext liefern.
- Z. B. Automatisierbarkeit, Sicherheitsanforderungen oder betroffene Komponenten.

Der CVSS-Prozess

- Der CVSS-Prozess verwendet ein Tool namens CVSS v4.0 Calculator.
(<https://www.first.org/cvss/calculator/4.0>)
- Der Rechner ist wie ein Fragebogen, in dem die Auswahlmöglichkeiten getroffen werden welche die Schwachstelle für jede Metrikgruppe beschreiben.
- Daraus wird eine Punktzahl generiert und der numerische Schweregrad wird angezeigt.



Common Vulnerability Scoring System Version 4.0 Calculator

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N

Reset

CVSS v4.0 Score: 0 / None ⊕

Hover over metric names and metric values for a summary of the information in the official CVSS v4.0 Specification Document. The Specification is available in the list of links on the left, along with a User Guide providing additional scoring guidance, an Examples document of scored vulnerabilities, a set of Frequently Asked Questions (FAQ), and both JSON and XML Data Representations for all versions of CVSS.

Base Metrics ?				
Exploitability Metrics				
Attack Vector (AV):	Network (N)	Adjacent (A)	Local (L)	Physical (P)
Attack Complexity (AC):	Low (L)	High (H)		
Attack Requirements (AT):	None (N)	Present (P)		
Privileges Required (PR):	None (N)	Low (L)	High (H)	
User Interaction (UI):	None (N)	Passive (P)	Active (A)	

Der CVSS-Prozess (2)

Nachdem jede einzelne Gruppe abgeschlossen ist erhält man eine Gesamtbewertung.

Diese Bewertung kann man auch als CVSS-String angeben, hier am Beispiel des CVE-2023-21989 (Oracle VirtualBox Vulnerability):

CVSS:4.0/AV:L/AC:L/AT:N/PR:H/UI:N/VC:N/VI:N/VA:N/SC:H/SI:N/SA:N

CVSS v4.0 Score: 5.9 / Medium ⊖

Macro vector: 102101

Exploitability: Medium

Complexity: High

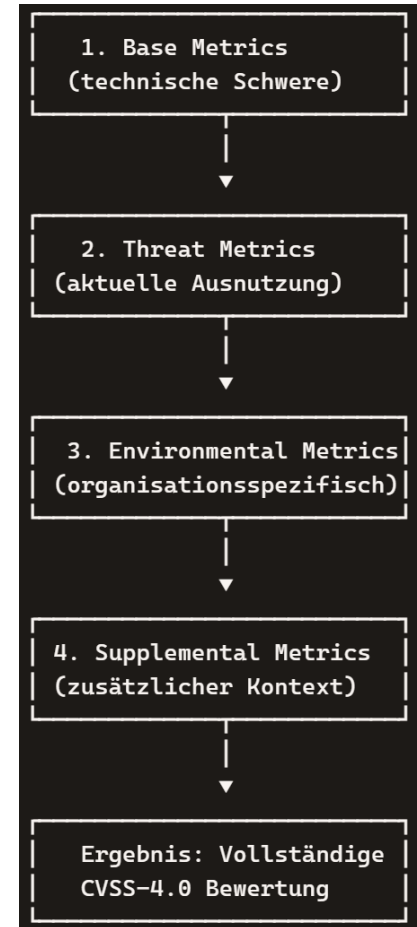
Vulnerable system: Low

Subsequent system: Medium

Exploitation: High

Security requirements: Medium

(dieses Beispiel zeigt nur den Score für die Base Metrics!)



CVSS-Reports

- Je höher der Schweregrad, desto grösser ist die potenzielle Auswirkung eines Angriffs und desto dringlicher ist die Behebung der Sicherheitslücke.
- **Empfehlung:** jede Schwachstelle, die den Wert 3,9 überschreitet, sollte zeitnah behoben werden.
- Für die Ratings darunter muss eine individuelle Risikobewertung gemacht werden → ggf. müssen auch diese Vulnerabilities behoben werden!

CVSS Score	Severity Rating
0.0	None
0.1 – 3.9	Low
4.0 – 6.9	Medium
7.0 – 8.9	High
9.0 – 10.0	Critical

Vulnerabilities Beurteilen: CVSS

Aufgabe:

- Berechnen Sie den CVSS 4.0 Score für "Log4J" (CVE-2021-44228)
- Wie würde sich der Score verändern wenn das betroffene System:
 - nur im internen Netz erreichbar wäre?
 - nur unkritische Daten der Unternehmung enthält?



Patch Management

- Patch-Management ist der Prozess der Verteilung und Durchführung von Updates für Software.
- Solche Patches sind oftmals notwendig, um Fehler in der Software zu beheben, beispielsweise aufgrund eines Vulnerability Assessments.
- Zu den häufigsten Bereichen, die Patches benötigen, gehören Betriebssysteme, Programme und Embedded-Systems (wie Netzwerkkomponenten, Router, Switches, Firewall, etc.).
- Wenn nach der Veröffentlichung einer Software eine Schwachstelle gefunden wird, kann ein Patch verwendet werden, um diese Schwachstelle zu beheben. Dies hilft dabei sicherzustellen, dass Assets in der IT-Umgebung nicht ausgenutzt werden können.

Patch Management Prozess

Der Patch-Management-Prozess bezieht sich auf die systematische Verwaltung und Implementierung von Software-Patches oder Updates.

Dieser Prozess umfasst mehrere Schritte, die sicherstellen, dass Patches effektiv und sicher auf IT-Systeme angewendet werden.

Patch management process

1. Do a baseline inventory
2. Standardize software versions
3. Categorize by risk and priority
4. Set up a test lab environment
5. Test patches
6. Gather patch, vulnerability and test information
7. Identify endpoints
8. Review patch management plan
9. Run a pilot
10. Document pre- and post-patching states
11. Audit patches



Weshalb ist Patch Management wichtig?

- **Sicherheit:** Patch-Management behebt Schwachstellen in der Software und den Anwendungen, die anfällig für Cyber-Angriffe sind, und hilft einem Unternehmen, sein Sicherheitsrisiko zu reduzieren.
- **Systemverfügbarkeit:** Das Patch-Management stellt sicher, dass die Software und Anwendungen auf dem neuesten Stand sind und reibungslos laufen, wodurch die Systemverfügbarkeit unterstützt wird.
- **Compliance:** Bedingt durch die ständig steigende Zahl von Cyber-Angriffen sind Unternehmen häufig gesetzlich verpflichtet, bestimmte Vorschriften einzuhalten. Patch-Management ist ein notwendiger Bestandteil der Einhaltung von Compliance-Standards.
- **Funktionsverbesserungen:** Patch-Management kann mehr sein als nur Bug-Fixes für Software, oftmals beinhalten sie auch Funktionsverbesserungen. Patches können entscheidend sein, um sicherzustellen, dass man das Neueste und Beste hat, was ein Produkt zu bieten hat.



Arten von Patches

- Es gibt verschiedene Nomenklaturen, je nach Hersteller
- Auch die Versionierung unterscheidet sich üblicherweise je nach Hersteller

Name	Reifegrad	Umfang	Versionierung	Bemerkung
Patch	stabil	spezifischer Fehler (Bug)	1.2.3 → 1.2.4	Eine spezifische Vulnerability beheben
Hotfix	instabil	spezifischer Fehler (Bug)	1.2.3 → 1.2.3(1)	Vulnerability schnellstmöglich beheben, ev. potentiell Workaround
Update	stabil	Patches seit letztem Update	1.2.3 → 1.3.0	neue Produktversion welche die Vulnerability behebt
Service Pack	stabil	Kumulative Sammlung aller Updates	1.7 → 1.8	Vermeidet Notwendigkeit, viele Updates nacheinander einzuspielen zu müssen
Upgrade	stabil	Alle ausstehenden Patches & neue Features	1.x.x → 2.0.0	Liefert neue Produktfeatures, nicht nur Vulnerability-Fixes (führt aber meistens neue Vulnerabilities ein ☹️)

Bereitstellen von Patches

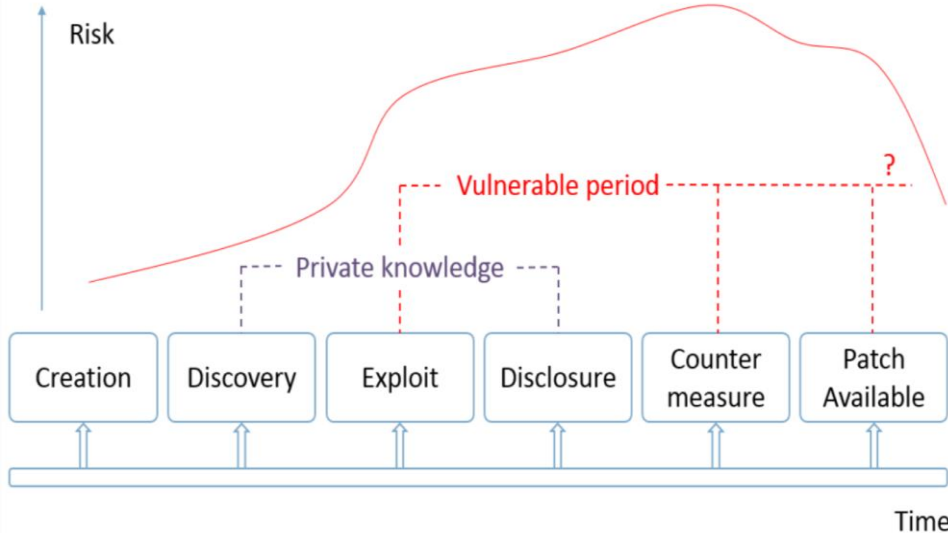
Das Patch-Window ist abhängig von der Art der Bekanntmachung der Vulnerability

- **Responsible Disclosure:**

Sicherheitsforscher finden Vulnerability, melden es Hersteller und stellen so sicher, dass Patch verfügbar ist ehe sie publizieren
→ Patch-Window erlaubt Patching ehe Attacken stattfinden können

- **Zero-Day Exploit:** Exploit Code wird ohne Responsible Disclosure publiziert
→ Patch-Window schrumpft erheblich oder verschwindet fast

- **Zero-Day Attack:** Kriminelle nutzen die Schwachstelle aus ehe sie bekannt wird
→ Patch-Window verschwindet komplett



Alternativen zu Patches (1)

Nicht immer gibt es (zeitgerecht) einen Patch (e.g. bei Zero-Day).
Folgende Alternativen stehen bereit:

1. **Abschaltung** (temporär oder permanent)

- System hochkritisch und Risiko einer Kompromittierung überwiegt Kosten eines Betriebsausfalls
- System nicht betriebskritisch oder Ersatzsystem vorhanden

2. **Alternativprodukt**

- Ersetzt das verwundbare Produkt durch eine sichere Alternative.

Meist keine kurzfristige Alternative (manchmal aber schon): viele Firmen haben 2 Browser installiert. Im Fall einer ernststen Schwachstelle kann ein Browser deaktiviert werden

3. **Funktionseinschränkung / Work-Around**

- Abschaltung spezifischer verwundbarer Funktionen kann sicheren Weiterbetrieb erzwingen
- Oft vom Hersteller empfohlen bis Patches verfügbar sind

Alternativen zu Patches (2)

4. **Netzwerkisolation**

- Isolation auf Netzwerkebene und spezifisches Whitelisting bestimmter Verbindungen kann Risiken reduzieren wo
- Systeme nur von spezifischen Personengruppen oder anderen Systemen aufgerufen werden müssen
- Temporäre Netzwerkisolation kann weniger aggressive Alternative zur temporären Abschaltung sein
- Potentiell werden temporäre Service-Einschränkungen in Kauf genommen

5. **Zugangsbeschränkungen**

- Einschränkungen der Zugriffe auf verwundbare Funktionalitäten auf bekannte und vertrauenswürdige Personen durch Zugangskontrolle

6. **Virtual-Patching**

- Vorschaltung eines Security Gateway (e.g. Web-Application-Firewall) welche Angriffe filtert

Alternativen zu Patches (3)

1. **Härten** reduziert die Exposure gegen Vulnerabilities und Attacken
 - Deaktivierung verwundbarer oder nicht genutzter Protokolle oder Services (z.B. Telnet, SMBv1)
 - Aktivierung vorhandener Sicherheitsprüfungen und Validierungsregeln (z.B. HSTS, CSP)
 - Aktivierung vorhandener Zugangskontrollmechanismen oder Beschränkungen (z.B. kein Root Login auf SSH, eingeschränkte Zugriffe auf Credential Stores wie /etc/shadow)
 - Nutzung von Hardware Sicherheitsmechanismen der CPU (z.B. Address Space Layout Randomization ASLR)
2. Herstellervorgaben: vor allem relevant wenn keine CIS-Benchmark vorhanden
 - Microsoft Security Baselines (<https://learn.microsoft.com/en-us/windows/security/operating-system-security/device-management/windows-security-configuration-framework/windows-security-baselines>)
 - vmWare Security Hardening Guide (<https://www.vmware.com/security/hardening-guides.html>)

Alternativen zu Patches (4)

3. Industry Best Practice: CIS-Benchmarks (<https://www.cisecurity.org/cis-benchmarks>)
 - Decken breites Spektrum ab: Betriebssysteme, Server Software, Desktop Software, Cloud Services
 - 2 Levels: Basic / Defense in Depth (plus STIG als 3. Level für einige Benchmarks, siehe unten)
 - Breiter Tool-Support für automatisierte Implementierung und Validierung
4. Alternative / Ergänzung: DISA STIG (US Department of Defense Systems Agency Security Technical Implementation Guides - <https://www.cyber.mil/stigs/>)



Was gehört sonst noch zum Patch-Management?

- Überprüft der Wirksamkeit von Patches vor dem produktiven Einsatz mit geeigneten Tests.
→ Updates können abhängig von der spezifischen unterliegenden Systemkonfiguration zu unerwarteten Ergebnissen bis hin zu Fehlfunktionen und Schäden führen
(<https://www.independent.co.uk/tech/microsoft-sued-court-windows-10-update-destroyed-peoples-data-damaged-pcs-a7651351.html> oder <https://duo.com/decipher/software-update-led-to-microsoft-azure-mfa-outage>)
- Planung und Koordination mit zuständigen Stellen für die Verteilung der sicherheitsrelevanten Patches auf die *produktive* Umgebung.
→ sicherstellen das die Patches "zur richtigen Zeit am richtigen Ort" sind, ggf. müssen Wartungsfenster eingeplant und bewilligt werden.
- Periodisches Überprüfen und Bewerten der Leistung und Wirksamkeit des Patch-Managements selbst und bei Bedarf vorschlagen von Verbesserungsmaßnahmen.
→ Messen von KPIs zur Bestimmung der Maturität des Prozesses
(<https://www.motadata.com/blog/patch-management-kpi-metrics/> oder <https://heimdalsecurity.com/blog/kpi-examples-for-patch-and-vulnerability-management/> oder <https://www.sans.org/white-papers/1461/>)

Vulnerability management vs. patch management

Patch management is part of vulnerability management, a much broader process for identifying and fixing cybersecurity issues. There is specialized software for each.

	Vulnerability management	Patch management
PURPOSE	■ Manage all security vulnerabilities	■ Manage software patching
MAIN FUNCTIONS	■ Discover, prioritize, assess, remediate and report vulnerabilities	■ Patch or upgrade software to remove security holes, fix bugs or add features
KEY STEPS	■ Inventory systems and software ■ Scan networked systems ■ Identify vulnerabilities ■ Evaluate and prioritize vulnerabilities ■ Remediate (patch or reconfigure) ■ If fix is unavailable or doesn't work: Mitigate or accept ■ Report (dashboards, analytics, compliance)	■ Inventory systems and software ■ Standardize software versions ■ Discover and acquire patches ■ Test ■ Create and approve plan ■ Install ■ Document
TYPICAL USERS	■ Cybersecurity team	■ IT

Patch management KPIs

METRIC	DESCRIPTION	RATIONALE
Percentage of systems and applications covered by automated patch management	Percentage of systems and applications inventoried and covered by automated patch management	Indicates the breadth of coverage of the patch management tools
Number of patches that failed quality assurance (QA) testing	Number of patches that failed the QA testing in the test environment	Indicates possible poor planning or development procedure problems
Number of patches that resulted in an incident ticket being generated	Failed implementation of a patch that affected user operation	Indicates possible poor planning or a problem with testing and QA procedures
Number of successful patch implementations versus the number of unsuccessful patch implementations	Provides an indication of how many new patches, on average, were implemented successfully	Indicates possible poor planning or a problem with testing and QA procedures
Average time elapsed between a patch's availability and its deployment	Measures time elapsed between patch availability and production deployment	Indicates the efficiency and effectiveness of patch management processes
Frequency of compliance checks	How often systems are automatically checked for compliance	Indicates the level of audit and compliance procedures